INTERNATIONAL CYBERSECURITY AND DIGITAL FORENSICS ACADEMY

GRC103 – RISK ASSESSMENT AND MANAGEMENT TECHNIQUES

Module 2: Risk Analysis And Evaluation

Role:Lead GRC Analyst

Lab 3A: Advanced GRC Phishing Simulation & Quantitative Risk Analysis

Student Name	Olubunmi Adesanmi
Registration number	C11/26/CGRCE 17550
Course	Grc 103-Risk Assessment and management techniques
Module	Risk Analysis And Evaluation
Lab	Phishing simulation metrics and quantitative Risk Analysis
Link to workbook	https://docs.google.com/spreadsheets/d/14y7oqt00_K3Uhgt4TW5B2jEp_fjhfOvZmJXRmacaoWY/edit?usp=sharing

Role	Lead Risk Analyst
Submission Date	Nov 1

LAB 3A: ADVANCED GRC PHISHING SIMULATION & QUANTITATIVE RISK ANALYSIS

Document Title	Lab 3A: Advanced GRC Phishing Simulation & Quantitative Risk Analysis
Organization	GlobalTech Inc.
Prepared by	Lead GRC Analyst
Intended audience	Board of Directors, CISO, CFO and GRC stakeholders
Version	1.1
Currency	United States Dollars (USD)
Classification	Internal— Training and Risk Assessment Exercise

TABLE OF CONTENTS

Executive Summary

1. Introduction and Assessment Objectives

2. Scope, Source Data and Methodology

3. Phase 1 – Basic Phishing Metrics

- 3.1 Fundamental Rates
- 3.2 Attack-Stage Conversion Metrics
- 3.3 Combined Results Across All Campaigns

4. Phase 2 – Advanced Risk Quantification

- 4.1 Workforce Projection
- 4.2 Financial Impact and Modelled ALE
- 4.3 Employee and Payroll Context

5. Phase 3 – Comprehensive Risk Assessment

- 5.1 Risk Assessment Matrix
- 5.2 Risk Interpretation
- 5.3 Statistical Confidence Intervals (95%)

6. Phase 4 – Executive Briefing and Control Economics

- 6.1 Board-Level Briefing
- 6.2 Stand-Alone Control Cost-Benefit Analysis
- 6.3 Proposed Security Investment Portfolio
- 6.4 Expected Risk Posture After Controls
- 6.5 Break-Even Analysis

7. Strategic Recommendations and Implementation Roadmap

8. Limitations, Assumptions and Corrections to the Supplied Brief

9. Conclusion

Appendix A – Formula Reference

Appendix B – References

EXECUTIVE SUMMARY

GlobalTech Inc. conducted three phishing simulations during the previous quarter involving 430 email sends across general employee and executive/assistant target groups. Across the three campaigns, 354 messages were opened, 257 links were clicked, 105 credential submissions were recorded, and 38 participants entered additional personal information.

The weighted credential-submission rate was 24.42% (105/430). Campaign B, titled IT System Password Reset, recorded the highest credential-submission rate at 30%, followed by Campaign A at 18% and Campaign C at 15%.

When Campaign B's credential-submission rate is projected across the organisation's 2,000 employees, the model estimates that 600 employees could submit their credentials. Applying

the scenario's 25% conditional probability of a major breach produces 150 expected breach-equivalent outcomes.

At the assumed $4.35 million loss per breach, the resulting modelled financial exposure is:

$4,350,000 × 150 = $652,500,000.

This represents a scenario-based financial exposure of $652.5 million. It is not a verified annual loss forecast because the calculation assumes that every expected breach-equivalent outcome creates a separate breach costing $4.35 million. Those assumptions must be validated before the figure is used as an actual organisational budget forecast.

The control calculations indicate potentially significant economic value under the assumptions supplied in the lab.

Enterprise Multi-Factor Authentication (MFA) costs $90,000 and, at the assumed 99.9% effectiveness, reduces the modelled exposure by $651.8475 million. Its calculated ROI is 724,175%.

Security awareness training costs $100,000 and, under the assumption that it reduces Campaign B's click-through rate by 60% while the post-click credential conversion remains unchanged, reduces modelled exposure by $391.5 million. Its calculated ROI is 391,400%.

Email filtering is modelled with an assumed 20% reduction in ALE because the lab does not provide a directly measured filtering effectiveness rate. Its calculated ROI is 260,900%.

These high ROI figures are mathematically consistent with the lab's large projected loss baseline. However, they should not be interpreted as reliable real-world investment returns until the loss model, annual occurrence frequency, control effectiveness, implementation costs and potential overlap between security controls are validated.

The recommended decision is to prioritise phishing-resistant MFA, targeted employee training, email protection and repeat measurement while establishing a defensible financial risk model.

Key Quantitative Findings

Risk Metric	Calculated Value	Comparator Supplied in Brief	Severity in Brief
Overall credential-submission rate	24.42%	15.3%	High
Maximum campaign credential rate	30%	18.7%	Critical

Campaign B modelled ALE	$652.5 million	$285 million	Severe
MFA stand-alone ROI	724,175%	350%	Excellent

Note: The comparator figures are reproduced from the lab brief. No supporting source, date, sector or matching metric definition was supplied. They are therefore treated as illustrative training inputs, not independently verified industry benchmarks.

Executive Decision Points

1. Prioritise Campaign B risk: Approve an enterprise MFA rollout, beginning with privileged, finance, HR and other high-risk accounts, with a funded path towards organisation-wide coverage.

2. Reduce human susceptibility: Deliver role-based training and repeat phishing simulations, with particular attention to password-reset lures and executive-targeted scenarios.

3. Improve email-layer prevention: Assess and strengthen the secure email gateway, URL protection, attachment sandboxing and reporting controls.

4. Validate the financial model: Distinguish compromised accounts from separate breach incidents and replace the assumed 150 annual events with a defensible annual frequency estimate.

5. Measure outcomes: Report credential submissions, phishing reporting rates, repeat susceptibility, MFA coverage and verified incidents quarterly.

1. INTRODUCTION AND ASSESSMENT OBJECTIVES

Phishing is a human-centred cyberattack technique that attempts to persuade users to open malicious messages, visit fraudulent websites, disclose credentials or provide other sensitive information.

For a Governance, Risk and Compliance (GRC) function, phishing simulation results provide useful evidence for identifying human-related vulnerabilities, evaluating control performance, prioritising risk treatment and communicating potential business exposure.

This assessment converts the three supplied phishing simulations into measurable rates, projects the results across the stated employee population, applies the supplied financial assumptions, assesses statistical uncertainty and evaluates proposed security investments.

The assessment follows the general risk-assessment principle of identifying threat conditions, vulnerabilities, likelihood, impact and appropriate risk responses (National Institute of Standards and Technology [NIST], 2012).

1.1 Assessment Objectives

The objectives of this exercise are to:

- Calculate fundamental phishing rates and attack-stage conversion metrics.
- Project the observed credential-submission rates across the organisation's 2,000 employees.
- Estimate scenario-based financial exposure using the supplied $4.35 million breach cost and 25% conditional probability.
- Assess campaign priorities and the statistical uncertainty of the sample estimates.
- Calculate the cost, risk-reduction benefit, net benefit and ROI of proposed security controls.
- Determine the break-even point for the proposed security investment.
- Provide executive-level recommendations and identify assumptions requiring further validation.

2. SCOPE, SOURCE DATA AND METHODOLOGY

2.1 Scope

This assessment covers Campaigns A, B and C, the supplied employee population and salary information, the assumed breach cost, the probability of a major breach following credential theft, and the proposed MFA, security training and email-filtering controls.

The dataset does not report an actual security incident, confirmed compromise or realised financial loss. Therefore, the analysis is a simulation-based risk projection rather than a report of actual organisational breaches.

2.2 Supplied Campaign Data

The following table presents the original phishing simulation results provided in the lab brief.

Campaign	Target Group	Emails Sent	Opened	Clicked	Credentials Submitted	Additional Data Entries

A – HR Bonus Notification	100 employees	100	82	47	18	5
B – IT System Password Reset	250 employees	250	200	150	75	25
C – CEO Urgent Document Review	80 executives and assistants	80	72	60	12	8
Total	430 target places	430	354	257	105	38

2.3 Organisational and Financial Assumptions

Input	Supplied Value	Application in Assessment
Total employees	2,000	Workforce projection
Average annual employee salary	$85,000	Contextual financial information
Implied annual payroll	$170,000,000	2,000 × $85,000
Cost per data breach (SLE)	$4,350,000	Assumed loss per breach-equivalent outcome
Probability of major breach if credentials are stolen	25%	Applied to projected credential submissions

MFA implementation cost	$45 per user / $90,000 total	Control investment
MFA effectiveness	99.9%	Assumed reduction in credential-theft impact
Training cost	$50 per user / $100,000 total	Control investment
Training effectiveness	60% reduction in click-through rate	Applied to Campaign B click-through rate
Email-filtering cost	$50,000	Control investment
Email-filtering effectiveness	20% ALE reduction assumed	Planning assumption inferred from supplied control table

2.4 Calculation Methodology and Terminology

The calculations use the following methodology:

1. Basic phishing rates use the number of emails sent as the denominator.
2. Conversion metrics use the number of users who reached the preceding attack stage as the denominator.
3. Workforce projections multiply the observed credential-submission rate by the total employee population of 2,000.
4. The lab's simplified financial model multiplies projected credential submissions by the 25% conditional breach probability.
5. The resulting expected breach-equivalent outcomes are multiplied by the assumed $4.35 million loss per breach.
6. Security control ROI is calculated using the risk-reduction benefit, control cost and net financial benefit.

For clarity, this report uses the term expected breach-equivalent outcomes for the results obtained by applying the 25% probability to projected credential submissions.

This does not establish a verified count of separate security incidents.

The term modelled ALE is used for the lab's financial calculation, subject to the limitations explained in Section 8.

The distinction between observed evidence, likelihood assumptions, impact estimates and risk-treatment decisions follows the structured approach to risk assessment described in NIST SP 800-30 Rev. 1 (NIST, 2012).

3. PHASE 1 – BASIC PHISHING METRICS

3.1 Fundamental Rates

The fundamental phishing metrics measure how employees responded to each simulated phishing email.

Formula:

$$Rate = \frac{Number of Events}{Number of Emails Sent} \times 100$$

The following calculations were performed for all three campaigns.

Completed Campaign Metrics

Campaign	Email Open Rate	Click-Through Rate	Credential-Submission Rate	Additional Data-Entry Rate
A	82/100 = 82.00%	47/100 = 47.00%	18/100 = 18.00%	5/100 = 5.00%
B	200/250 = 80.00%	150/250 = 60.00%	75/250 = 30.00%	25/250 = 10.00%
C	72/80 = 90.00%	60/80 = 75.00%	12/80 = 15.00%	8/80 = 10.00%

Worked Calculations

Campaign B – Email Open Rate

200/250 x 100=80%

Campaign B – Click-Through Rate

150/250 x 100=60%

Campaign B – Credential-Submission Rate

75 / 250 x 100=30%

Campaign B – Additional Data-Entry Rate

25 / 250 x 100=10%

Figure 1: Phishing Simulation Results by Campaign

The recommended chart for this section is a clustered column chart comparing the four campaign metrics.

Metric	Campaign A	Campaign B	Campaign C
Email open rate	82%	80%	90%
Click-through rate	47%	60%	75%
Credential-submission rate	18%	30%	15%
Additional data-entry rate	5%	10%	10%

Interpretation:

Campaign C recorded the highest email open rate at 90%, meaning that most of the targeted executives and assistants opened the simulated message.

However, Campaign B recorded the highest credential-submission rate at 30%. This indicates that the IT password-reset message was particularly effective at persuading recipients to disclose their credentials.

Campaign B should therefore receive immediate attention from the organisation's security and GRC teams.

3.2 Attack-Stage Conversion Metrics

Conversion metrics measure how effectively the simulated phishing attack moved employees from one stage to another.

Two conversion metrics were calculated.

A. Open-to-Click Conversion

Formula:

$$Open - to - ClickConversion = \frac{EmailsClicked}{EmailsOpened} \times 100$$

Calculations:

Campaign A

47 / 82 x 100=57.32%

Campaign B

150/200 x 100=75.00%

Campaign C

60/72 x 100=83.33%

B. Post-Click Credential-Submission Conversion

This metric measures the percentage of employees who clicked a phishing link and subsequently submitted their credentials.

Formula:

$$Post - ClickSubmission = \frac{CredentialsSubmitted}{EmailsClicked} \times 100$$

Calculations:

Campaign A

18 / 47 x 100=38.30%

Campaign B

75 / 150 x 100=50.00%

Campaign C

12 / 60 x 100=20.00%

Completed Conversion Metrics

Campaign	Open-to-Click Conversion	Post-Click Credential-Submission Conversion
A	57.32%	38.30%
B	75.00%	50.00%
C	83.33%	20.00%

Interpretation:

Campaign C had the highest open-to-click conversion rate at 83.33%. This means that a high proportion of employees who opened the message proceeded to click its link.

However, Campaign C had the lowest post-click credential-submission conversion at 20%.

Campaign B converted 50% of all link clickers into credential submitters. This helps explain why it produced the highest overall credential-submission rate.

The findings demonstrate why GRC professionals should not rely on only one phishing metric. Analysing the different attack stages provides a more complete understanding of human susceptibility.

3.3 Combined Results Across All Campaigns

The combined results provide an overall view of employee responses across the three simulations.

The total emails sent were:

$$100 + 250 + 80 = 430$$

The combined metrics are calculated as follows:

Metric	Calculation	Combined Rate
Email open rate	354/430 × 100	82.33%
Click-through rate	257/430 × 100	59.77%
Credential-submission rate	105/430 × 100	24.42%
Additional data-entry rate	38/430 × 100	8.84%

The combined credential-submission rate is 24.42%, not 22.1%.

These combined rates are weighted by email volume. They represent campaign-send-level statistics and should not be described as a unique-employee rate unless the organisation confirms that the three target groups do not overlap.

4. PHASE 2 – ADVANCED RISK QUANTIFICATION

This phase translates the phishing simulation findings into estimated organisational exposure and financial risk.

The purpose is to demonstrate how a GRC professional can move from identifying a vulnerability to quantifying its potential business consequences.

4.1 Workforce Projection

The organisation has 2,000 employees. The highest credential-submission rate was recorded in Campaign B, making it the most significant campaign for this projection.

Formula:

Projected Credential Submissions =Total Employees x Credential Rate

Campaign B credential-submission rate:

75/250 x 100 =0.30=30%

Projected credential submissions:

$$2,000 \times 0.30 = 600$$

Therefore, 600 employees could potentially submit their credentials if Campaign B's observed rate applied across the entire workforce.

Expected Breach-Equivalent Outcomes

The scenario states that the probability of a major breach following credential theft is 25%.

Formula:

Expected Outcomes =Projected Credential Submissions x Breach Probability

$$600 \times 0.25 = 150$$

Therefore, the model produces 150 expected breach-equivalent outcomes.

Comparison of the Three Campaigns

Campaign	Credential-Submission Rate	Projected Credential Submissions	Expected Breach-Equivalent Outcomes
A	18%	2,000 × 0.18 = 360	360 × 0.25 = 90
B	30%	2,000 × 0.30 = 600	600 × 0.25 = 150
C	15%	2,000 × 0.15 = 300	300 × 0.25 = 75

Interpretation:

Campaign B presents the highest potential exposure because it has the highest credential-submission rate.

Campaign A and Campaign C also demonstrate meaningful susceptibility. However, these are three alternative scenarios projected against the same workforce. Their projected

outcomes should not be added together because doing so would count the same workforce more than once.

4.2 Financial Impact and Modelled Annualized Loss Expectancy

Annualized Loss Expectancy (ALE) estimates the financial loss associated with a risk over a year.

Formula:

$$ALE = SLE \times ARO$$

Where:

- SLE (Single Loss Expectancy): The estimated financial loss associated with one successful breach.
- ARO (Annual Rate of Occurrence): The expected frequency of the loss event per year.
- ALE (Annualized Loss Expectancy): The estimated annual financial loss.

Campaign B Financial Calculation

The supplied assumptions are:

Financial Input	Value
Single Loss Expectancy	$4,350,000
Expected breach-equivalent outcomes	150
Assumed loss per outcome	$4,350,000

Using the lab's simplified model:

ALE=$4,350,000 x 150
ALE=$652,500,000

The resulting modelled financial exposure is $652.5 million.

Financial Exposure Across All Campaigns

Campaign	Expected Breach-Equivalent Outcomes	Assumed Loss per Outcome	Modelled Financial Exposure
A	90	$4,350,000	$391,500,000
B	150	$4,350,000	$652,500,000
C	75	$4,350,000	$326,250,000

Figure 2: Scenario-Based Financial Exposure by Campaign

The recommended chart is a column chart comparing the financial exposure of the three campaigns.

Campaign	Financial Exposure
A – HR Bonus Notification	$391.50 million
B – IT System Password Reset	$652.50 million
C – CEO Urgent Document Review	$326.25 million

Interpretation:

Campaign B has the highest modelled financial exposure at $652.5 million. This reinforces the need to prioritise identity security, MFA and password-reset process improvements.

Campaign A has a modelled exposure of $391.5 million, while Campaign C has a modelled exposure of $326.25 million.

The figures are based on the simplified financial assumptions supplied in the lab. They should not be interpreted as confirmed financial losses or independently verified annual breach forecasts.

4.3 Employee and Payroll Context

The organisation has 2,000 employees, with an average annual salary of $85,000.

Formula:

Annual Payroll = Number of Employees x Average Salary
2,000 x $85,000=$170,000,000

The implied annual payroll is $170 million.

The modelled Campaign B exposure per employee is:

$652,500,000/2,000}=$326,250

Metric	Value
Total employees	2,000
Average annual salary	$85,000
Implied annual payroll	$170,000,000
Campaign B modelled exposure	$652,500,000
Modelled exposure per employee	$326,250

The $326,250 figure represents an allocation of modelled organisational exposure per employee. It does not mean that every employee individually creates or is expected to suffer that amount of financial loss.

The salary information is used for financial context only. Salary and payroll costs have not been added to the breach cost because the brief does not provide separate productivity-loss assumptions. Adding them without further evidence could result in double-counting.

5. PHASE 3 – COMPREHENSIVE RISK ASSESSMENT

This phase evaluates the identified phishing risks and determines which campaigns require immediate attention.

Risk assessment allows GRC professionals to prioritise vulnerabilities according to their likelihood, potential impact and business significance.

5.1 Risk Assessment Matrix

The following matrix combines the campaign credential-submission rates, additional data-entry rates, modelled financial exposure and recommended treatments.

Campaign	Credential Rate	Additional Data-Entry Rate	Modelled Exposure	Provisional Risk Level	Priority	Recommended Treatment
A – HR Bonus Notification	18%	5%	$391.50M	Medium-High	2	Targeted HR awareness training; verification of payroll and bonus requests; MFA
B – IT System Password Reset	30%	10%	$652.50M	Critical	1	Immediate MFA priority; password-reset process hardening; email protection; targeted training

C – CEO Urgent Document Review	15%	10%	$326.25 M	High	3	Executive and assistant-focused training; verified document-sharing procedures; stronger account protection

Note: These are provisional qualitative ratings based on the supplied simulation results. The brief does not provide formal organisational risk-rating thresholds.

5.2 Risk Interpretation

Campaign A – HR Bonus Notification

Medium-High Risk

Campaign A recorded an 18% credential-submission rate, meaning 18 out of 100 targeted employees submitted their credentials.

The HR bonus notification theme may exploit employees' interest in salary adjustments, bonuses and employee benefits.

The main risk is that attackers could use stolen credentials to access employee accounts or other systems accessible through those accounts.

Recommended actions:

- Conduct targeted HR security awareness training.
- Reinforce verification procedures for salary and bonus notifications.
- Implement MFA.
- Encourage employees to report suspicious HR-related messages.

Campaign B – IT System Password Reset

Critical Risk

Campaign B recorded the highest credential-submission rate at 30%.

Out of 250 employees who received the simulated email, 75 submitted their credentials.

The password-reset theme demonstrates how attackers may exploit employees' trust in IT support and routine account-maintenance procedures.

This campaign also generated the highest modelled financial exposure of $652.5 million.

Recommended actions:

- Prioritise enterprise-wide MFA.
- Review and strengthen password-reset procedures.
- Implement additional identity verification for password changes.
- Strengthen email filtering and malicious-link protection.
- Deliver targeted IT security awareness training.
- Monitor unusual login activity and possible account compromise.

Campaign C – CEO Urgent Document Review

High Risk

Campaign C targeted 80 executives and assistants and recorded a 15% credential-submission rate.

Although this was lower than Campaign A and Campaign B, the campaign targeted individuals whose accounts may have access to confidential business information and sensitive organisational processes.

The additional data-entry rate was 10%.

Recommended actions:

- Conduct specialised executive and assistant security training.
- Introduce verified document-sharing procedures.
- Strengthen account access controls.
- Monitor privileged and sensitive account activity.
- Reinforce verification of urgent executive instructions.

5.3 Statistical Confidence Intervals (95%)

Statistical confidence intervals help determine how reliable the observed phishing simulation rates may be when used to make broader assumptions about an employee population..

Formula:

$$CI = p \pm 1.96 \times \sqrt{\frac{p(1-p)}{n}}$$

Where:

- p = Observed success rate expressed as a decimal.
- n = Sample size.
- 1.96 = Z-score for an approximate 95% confidence interval.
- The square-root expression is the standard error.

Campaign A – Worked Calculation

Campaign A recorded:

- Credential submissions = 18.
- Emails sent = 100.
- Observed credential-submission rate = 18%.
- Sample size = 100.

Therefore:

$$p = \frac{18}{100} = 0.18$$

$$n = 100$$

Step 1: Standard error.

$$SE = \sqrt{\frac{0.18(1-0.18)}{100}}$$

$$SE = \sqrt{\frac{0.18 \times 0.82}{100}}$$

$$SE = \sqrt{0.001476}$$

$$SE = 0.03842$$

Step 2: Margin of error.

$$ME = 1.96 \times 0.03842$$

$$ME = 0.07530$$

Converted into a percentage:

ME=7.53%

Step 3: Calculating the confidence interval.

CI=18%pm 7.53%

Lower limit:

18%-7.53%=10.47%

Upper limit:

18%+7.53%=25.53%

Therefore:

95% CI=10.47% to 25.53%

Confidence Interval Results for All Three Campaigns

Campaign	Observed Credential Rate	Sample Size (n)	Margin of Error	Approximate 95% Confidence Interval
A	18.00%	100	±7.53 percentage points	10.47% – 25.53%
B	30.00%	250	±5.68 percentage points	24.32% – 35.68%
C	15.00%	80	±7.82 percentage points	7.18% – 22.82%

Interpretation of the Statistical Results

Campaign B has the largest sample size of 250 and the smallest margin of error of approximately 5.68 percentage points.

Campaign C has the smallest sample size of 80 and the widest confidence interval.

This demonstrates why sample size is important when interpreting phishing simulation results.

A 95% confidence interval does not mean that 95% of employees will fall within the calculated range. Rather, under the assumptions of the method, the interval provides an estimate of the uncertainty around the observed sample rate.

The confidence intervals calculated here use the approximate normal (Wald) method specified in the study guide. Their interpretation depends on sufficiently independent and representative observations.

The campaign target groups also differ by role. Therefore, these intervals do not automatically establish the organisation-wide susceptibility rate. A larger, repeated and stratified phishing simulation programme would provide stronger evidence.

6. PHASE 4 – EXECUTIVE BRIEFING AND CONTROL ECONOMICS

This section presents the findings in a format suitable for executive decision-making.

It also evaluates the proposed security investments by comparing their implementation costs against their estimated financial risk-reduction benefits.

6.1 Board-Level Executive Briefing

To: Board of Directors, Chief Information Security Officer (CISO), Chief Financial Officer (CFO)
From: GRC Risk Analysis Team
Date: 1 November 2026
Subject: Quantitative Phishing Risk Assessment and Campaign B Financial Exposure

Executive Briefing

The three phishing simulations conducted at GlobalTech Inc. revealed a significant level of employee susceptibility to phishing attacks.

The combined credential-submission rate was 24.42%, with Campaign B recording the highest rate at 30%.

Applying Campaign B's observed rate to the organisation's total workforce of 2,000 employees produces an estimated 600 credential submissions. Under the lab's simplified 25% conditional breach probability and $4.35 million loss assumptions, this produces 150 expected breach-equivalent outcomes and a modelled financial exposure of $652.5 million.

This figure is suitable as a scenario-based risk indicator for the exercise. However, it is not yet a validated annual loss forecast. The organisation must distinguish compromised accounts from separate breach incidents and establish a defensible annual occurrence frequency before using the figure as an actual financial forecast.

The immediate control priorities are to strengthen identity protection through MFA, reduce employee susceptibility through targeted awareness training, and improve email-layer security controls.

The proposed security investments should be implemented in stages, linked to measurable control outcomes and reassessed through repeat phishing simulations and actual incident data.

Key Findings for the Board

Area	Finding	Business Significance

Employee susceptibility	24.42% combined credential-submission rate	Demonstrates a material human-related security weakness
Highest-risk campaign	Campaign B – 30% credential-submission rate	Identifies password-reset-themed phishing as the immediate priority
Workforce projection	600 projected credential submissions	Indicates potential exposure of employee accounts
Financial exposure	$652.5 million modelled Campaign B exposure	Demonstrates the potential financial significance under the lab assumptions
Control priority	MFA, training and email protection	Provides a basis for security investment decisions
Statistical reliability	Different confidence intervals across campaigns	Highlights the need for repeated and representative testing

6.2 Stand-Alone Control Cost-Benefit Analysis

Cost-benefit analysis allows the organisation to determine whether the estimated financial benefits of security controls justify the costs of implementing them.

Return on Investment Formula

$$ROI = \frac{Benefit - Cost}{Cost} \times 100$$

Where:

- Benefit = Estimated financial risk reduction.
- Cost = Cost of implementing the security control.
- Net benefit = Risk reduction benefit minus implementation cost.

Control Recommendation Table

Control	Implementation Cost	Assumed Effectiveness	Risk-Reduction Benefit	Net Benefit	ROI	Modelled Residual ALE
MFA Implementation	$90,000	99.9% reduction in credential-theft impact	$651,847,500	$651,757,500	724,175%	$652,500
Security Awareness Training	$100,000	60% reduction in Campaign B click-through rate	$391,500,000	$391,400,000	391,400%	$261,000,000
Email Filtering	$50,000	20% ALE reduction assumed	$130,500,000	$130,450,000	260,900%	$522,000,000

Note: The three controls are evaluated independently against the same baseline ALE of $652.5 million. Their benefits must not be added together as though each control independently removes a separate portion of risk.

A. Multi-Factor Authentication (MFA) Cost-Benefit Analysis

MFA requires users to provide additional verification when accessing organisational systems.

This reduces reliance on passwords as the only authentication mechanism and can help prevent unauthorised account access when credentials are stolen.

Given:

- Total employees = 2,000.
- Cost per user = $45.
- MFA effectiveness = 99.9%.
- Current modelled ALE = $652,500,000.

Step 1: Implementation cost.

MFA Cost =2,000 x $45
=$90,000

Step 2: Calculate risk-reduction benefit.

Risk Reduction=Current ALE x Effectiveness
=$652,500,000 x 0.999
= $651,847,500

Step 3: Calculating residual risk.

$$NewALE = CurrentALE \times (1 - Effectiveness)$$

= $652,500,000 x 0.001
=$652,500

Step 4: Net financial benefit.

$$NetBenefit = RiskReduction - ControlCost$$

=$651,847,500-$90,000
= $651,757,500

Step 5: Calculating ROI.

ROI= $651,847,500 - $90,000 /$90,000 x 100
= 724,175%

MFA Analysis:

Under the lab's assumptions, MFA provides the highest stand-alone ROI and the greatest modelled financial risk reduction.

It should therefore be the first control priority.

In practical implementation, the organisation should evaluate phishing-resistant authentication methods, account recovery procedures, exception management and coverage of privileged accounts rather than assuming that every MFA method provides identical protection.

B. Security Awareness Training Cost-Benefit Analysis

Security awareness training aims to improve employee understanding of phishing techniques and reduce the likelihood of users interacting with malicious messages.

The lab assumes a 60% reduction in Campaign B's click-through rate.

Given:

- Training cost per user = $50.
- Total employees = 2,000.

- Current Campaign B click-through rate = 60%.
- Training effectiveness = 60% reduction.
- Post-click credential conversion = 50%.
- Conditional breach probability = 25%.
- Cost per breach = $4,350,000.

Step 1: Training cost.

Training Cost=2,000 x $50
=$100,000

Step 2: New click-through rate.

$$NewCTR = CurrentCTR \times (1 - Effectiveness)$$

=60% x (1-0.60)
=60% x 0.40
=24%

Step 3: Calculate the new credential-submission rate.

The post-click credential conversion remains at 50%.

New Credential Rate =24% x 50%
=12%

Step 4: Calculate new projected credential submissions.

$$2,000 \times 0.12$$

=240 employees

Step 5: Calculate expected breach-equivalent outcomes.

$$240 \times 0.25$$

= 60

Step 6: Calculate new modelled ALE.

ALE=60 x $4,350,000
=$261,000,000

Step 7: Calculate financial risk reduction.

$$RiskReduction = CurrentALE - NewALE$$

=$652,500,000 - $261,000,000
=$391,500,000

Step 8: Calculate ROI.

ROI=$391,500,000-$100,000/ $100,000 x 100
=391,400%

Training Analysis:

The training programme is expected to reduce employee susceptibility, particularly to password-reset-themed phishing messages.

The correct new click-through rate is 24%, while 12% is the resulting credential-submission rate when the post-click conversion remains at 50%.

This distinction is important because click-through and credential-submission rates measure different stages of a phishing attack.

C. Email Filtering Cost-Benefit Analysis

Email filtering is designed to identify and block suspicious or malicious emails before they reach users.

Possible capabilities include:

- Sender verification.
- Malicious URL detection.
- Attachment scanning.
- Impersonation protection.
- Spam and phishing detection.
- Suspicious attachment sandboxing.

The lab does not provide an independently measured email-filtering effectiveness figure. For this calculation, a 20% ALE reduction is used as an explicit planning assumption inferred from the supplied control recommendation table.

Given:

- Email filtering cost = $50,000.
- Current modelled ALE = $652,500,000.
- Assumed risk reduction = 20%.

Step 1: Risk-reduction benefit calculation

Risk Reduction=$652,500,000 x 0.20
=$130,500,000

Step 2: Residual ALE

New ALE=$652,500,000-$130,500,000
=$522,000,000

Step 3: Calculate net financial benefit.

Net Benefit=$130,500,000 - $50,000

=$130,450,000

Step 4: Calculate ROI.

ROI=$130,500,000 - $50,000 / $50,000 x 100
=260,900%

Email Filtering Analysis:

Email filtering provides an additional preventive control by reducing the number of malicious messages that reach employees.

It should complement, rather than replace, MFA and employee security awareness training.

Its assumed 20% effectiveness should be validated through actual email-security performance data.

Figure 3: Stand-Alone Control Risk-Reduction Scenarios

The recommended chart is a horizontal bar chart comparing the gross modelled financial risk reduction provided by each control.

Control	Modelled Risk Reduction
MFA	$651,847,500
Security awareness training	$391,500,000
Email filtering	$130,500,000

Figure 4: Stand-Alone Control ROI

The recommended chart is a horizontal bar chart comparing the percentage ROI of the proposed controls.

Control	ROI

MFA	724,175%
Security awareness training	391,400%
Email filtering	260,900 %

Overall Interpretation:

MFA has the highest modelled financial return, followed by security awareness training and email filtering.

However, these are stand-alone calculations based on the same financial exposure baseline. The benefits should not be summed to claim that the controls collectively eliminate more risk than is present.

The actual effectiveness of each control will depend on implementation quality, coverage, maintenance and the attack paths being addressed.

6.3 Proposed Security Investment Portfolio

The brief recommends a broader security investment portfolio consisting of six initiatives.

Proposed Investment Breakdown

No.	Security Initiative	Proposed Cost
1	Enterprise-wide MFA implementation	$90,000
2	Targeted phishing simulation programme	$25,000
3	Emergency security awareness training	$100,000

4	Advanced email security gateway	$50,000
5	Continuous security monitoring	$150,000
6	Security behaviour analytics	$75,000
	Total Investment	$490,000

The total proposed security investment is:

$90,000+$25,000+$100,000+$50,000+$150,000+$75,000
=$490,000

Portfolio Risk-Reduction Scenario

The lab proposes a 90% aggregate risk-reduction target.

Because individual effectiveness values were not supplied for all six initiatives, the 90% reduction is treated as a planning target rather than an established result.

Step 1: Calculate target financial risk reduction.

Risk Reduction}=Current ALE x 90%
=$652,500,000 x 0.90
=$587,250,000

Step 2: Calculate residual modelled ALE.

Residual ALE =$652,500,000-$587,250,000
=$65,250,000

Step 3: Net financial benefit.

Net Benefit =$587,250,000-$490,000
=$586,760,000

Step 4: Calculate indicative portfolio ROI.

ROI=$587,250,000-$490,000 / $490,000 x 100
=119,746.94%

Portfolio Financial Summary

Financial Metric	Amount
Current modelled ALE	$652,500,000
Total proposed investment	$490,000
Target risk reduction	$587,250,000
Residual modelled ALE	$65,250,000
Net financial benefit	$586,760,000
Indicative portfolio ROI	119,746.94%

This is a target-based scenario, not an evidenced financial forecast.

The 90% reduction should be validated through implementation testing, repeated simulations and operational security measurements.

Monitoring and behaviour analytics should not be assigned financial benefits until their actual effect on incident likelihood, detection, containment or loss magnitude has been established.

6.4 Expected Risk Posture After Controls

The lab proposes reducing phishing susceptibility and financial exposure by 90%.

Applying this target consistently to the combined credential-submission rate and Campaign B modelled ALE produces the following illustrative results.

Metric	Current State	With 90% Reduction Target	Reduction
Combined credential-submission rate	24.42%	2.44%	90%
Campaign B credential-submission rate	30.00%	3.00%	90%
Campaign B modelled ALE	$652.50M	$65.25M	90%
Organisation-wide probability of at least one major breach	Not established	Not established	Not calculable

The 90% reduction represents a proposed management target, not a measured post-implementation result.

The original brief's 93.75% current breach probability and 25% post-control breach probability are not supported by the supplied calculation inputs and should not be reported as established organisational metrics.

6.5 Break-Even Analysis

Break-even analysis determines the number of breach-equivalent losses that must be avoided for the security investment to justify its cost.

The lab proposes a total security investment of $490,000.

The cost of one assumed data breach is $4,350,000.

Formula:

$$Break - evenBreaches = \frac{TotalSecurityInvestment}{CostperBreach}$$

Substituting the values:

=$490,000 /$4,350,000
=0.1126{ breach-equivalents}

Interpretation

The organisation needs to prevent approximately 0.1126 of the assumed breach-equivalent loss to recover the proposed $490,000 investment on an expected-loss basis.

Because actual breach incidents are whole events, preventing one full breach would exceed the investment cost, assuming the $4.35 million loss estimate applies and that the loss is genuinely avoidable through the proposed controls.

The investment only needs to reduce the $652.5 million modelled baseline by approximately:

$490,000/$652,500,000 x 100
=0.0751%

to equal its cost.

This mathematical break-even point is driven by the very large modelled baseline. It must not be interpreted as proof that the underlying financial exposure is realistic.

7. STRATEGIC RECOMMENDATIONS AND IMPLEMENTATION ROADMAP

Based on the findings, GlobalTech Inc. should implement a layered security strategy that addresses both technological weaknesses and human-related vulnerabilities.

The recommendations are divided into immediate actions and strategic initiatives.

7.1 Immediate Actions – First 90 Days

1. Implement Enterprise-Wide MFA

MFA should be prioritised because Campaign B demonstrated a significant credential-submission rate.

The organisation should:

- Prioritise privileged and high-impact accounts.
- Extend MFA coverage across the workforce.
- Prefer phishing-resistant methods such as FIDO/WebAuthn or suitable PKI-based authentication.
- Establish secure account recovery procedures.
- Document and monitor MFA exceptions.

2. Strengthen Password-Reset Procedures

The Campaign B results indicate that employees may be vulnerable to fraudulent password-reset requests.

The organisation should:

- Require strong identity verification before password changes.
- Strengthen help-desk identity verification procedures.
- Notify employees when account credentials are changed.
- Monitor unusual authentication activity.
- Review password-reset workflows regularly.

3. Conduct Targeted Security Awareness Training

Training should address the specific attack methods demonstrated in the simulations.

Priority training topics include:

- Recognising password-reset phishing.
- Identifying suspicious HR and payroll requests.
- Verifying executive instructions.
- Identifying fraudulent document-sharing links.
- Reporting suspicious emails.
- Protecting employee credentials.

4. Improve Email Security Controls

The organisation should evaluate:

- Email sender authentication.
- Malicious URL detection.
- Attachment scanning and sandboxing.
- Impersonation protection.
- Spam and phishing detection.
- External-sender warnings.

5. Establish a Phishing Reporting Process

Employees should have a straightforward process for reporting suspicious messages.

The security team should ensure that reported phishing messages are reviewed, classified and investigated appropriately.

7.2 Strategic Initiatives – Next 6 to 12 Months

No.	Strategic Initiative	Expected Outcome	Suggested Timeline
1	Quarterly phishing simulations	Measure employee susceptibility and improvement	Quarterly

2	Enterprise MFA coverage monitoring	Improve identity security	3–6 months
3	Advanced email security gateway	Strengthen email threat prevention	3–6 months
4	Continuous security monitoring	Improve threat detection and response	6–9 months
5	Security behaviour analytics	Identify unusual user and account behaviour	6–12 months
6	Financial risk model validation	Improve accuracy of ALE and investment decisions	3–6 months

Monitoring and behaviour analytics should be implemented with defined objectives, measurable performance indicators and appropriate data-protection safeguards.

7.3 Suggested Quarterly Security KPIs

The following Key Performance Indicators (KPIs) should be used to monitor the effectiveness of the recommended security initiatives.

KPI	Baseline from Supplied Simulations	Suggested Management Objective
Credential-submission rate	24.42% combined; 30% Campaign B	Reduce quarter-on-quarter and establish a formal target after baseline validation
Click-through rate	59.77% combined; 60% Campaign B	Reduce through layered controls and targeted coaching

Additional data-entry rate	8.84% combined	Reduce to zero and investigate every submission event
MFA coverage	Not supplied	100% workforce account coverage, with documented exceptions
Phishing reporting rate	Not supplied	Establish baseline and improve reporting
Repeat-susceptibility rate	Not supplied	Track by employee group and provide targeted coaching
Mean time to triage reported phishing	Not supplied	Establish baseline and improve quarterly

Monitoring and Reporting

The GRC team should present a quarterly report to management showing:

1. Changes in phishing susceptibility.
2. MFA implementation and coverage.
3. Number of phishing emails reported.
4. Confirmed phishing-related security incidents.
5. Control weaknesses requiring remediation.
6. Financial exposure and revised risk estimates.
7. Progress against the security investment roadmap.

This will allow management to evaluate whether the investments are achieving their intended outcomes.

8. LIMITATIONS, ASSUMPTIONS

A quantitative risk assessment should distinguish between observed results, assumptions, estimates and verified financial outcomes.

The following limitations and corrections are important when interpreting this assessment.

8.1 Limitations and Assumptions

1. Breach-event assumption

The calculation of 600 projected credential submissions multiplied by a 25% conditional probability produces 150 expected breach-equivalent outcomes.

It does not establish that 150 separate organisational breaches will occur.

Applying a full $4.35 million breach cost to every account-level outcome may materially overstate financial exposure.

2. Annual Rate of Occurrence (ARO)

The ALE formula requires an annual occurrence frequency.

The lab provides phishing simulation results from the previous quarter but does not establish that 150 breach-equivalent outcomes would recur every year.

Therefore, the $652.5 million figure is treated as a lab-modelled ALE proxy rather than a verified annual loss forecast.

3. Probability statement

The figure of 150 expected outcomes is a projected count under the simplified model.

It is not equivalent to a 93.75% probability of a major breach.

The supplied 93.75% figure has no valid derivation from the provided inputs and should not be reported as the organisation's actual breach probability.

4. Campaign matrix arithmetic

Campaign A's correct modelled exposure is $391.5 million, not $156.6 million.

Campaign C's correct modelled exposure is $326.25 million, not $104.4 million.

The corrected figures follow the formula and values provided in the lab.

5. Security training calculation

Reducing Campaign B's 60% click-through rate by 60% produces a new click-through rate of 24%, not 12%.

The 12% figure is the resulting credential-submission rate when the 50% post-click conversion remains unchanged.

6. Email-filtering effectiveness

The 20% ALE reduction is a planning assumption inferred from the proposed benefit in the supplied table.

It is not an independently measured control effectiveness result.

7. Portfolio risk reduction

The 90% aggregate reduction is a management target.

The lab does not provide enough information to independently calculate the combined effectiveness of simulations, monitoring, behaviour analytics, MFA, training and email filtering.

8. ROI interpretation

The very high ROI figures result from comparing relatively small implementation costs against a very large modelled financial exposure.

They should not be presented as reliable financial investment forecasts until the loss assumptions and control effectiveness values have been validated.

9. Sample representativeness

The simulations targeted different employee groups.

The data may not represent a random, independent sample of the entire workforce.

The confidence intervals are approximate and do not eliminate sampling or selection bias.

10. Industry benchmarks

The industry comparison figures supplied in the brief and study guide are not accompanied by sources, dates, sectors or matching metric definitions.

They are treated as illustrative training information rather than verified industry benchmarks.

11. Salary information

The $85,000 average annual salary is used to calculate contextual organisational payroll.

No additional salary-based loss is included in the breach calculations because the brief does not provide separate productivity-loss assumptions.

12. Additional data entries

The 38 additional data-entry events may overlap with credential submissions.

They are reported separately and are not added to credential submissions as though they represent 38 additional distinct victims.

8.2 Corrections to Headline Values

The following table summarises the important discrepancies identified in the supplied brief.

Item	Value in Supplied Brief	Corrected Value or Treatment
Combined credential-submission rate	22.1%	24.42% (105/430)
Campaign A modelled exposure	$156.6M	$391.5M
Campaign C modelled exposure	$104.4M	$326.25M
New Campaign B click-through rate after 60% reduction	12%	24%
New Campaign B credential-submission rate	Not correctly distinguished	12%
Email-filtering ROI	260,800%	260,900% under the 20% benefit assumption
Portfolio risk reduction	$587.5M	$587.25M
Net portfolio benefit	$587.01M	$586.76M
Current breach probability	93.75%	Not supported by supplied data

9. CONCLUSION

The three phishing simulations conducted at GlobalTech Inc. identified a significant human-related security risk that requires management attention.

Campaign B, the IT System Password Reset simulation, recorded the highest credential-submission rate at 30%. Its results indicate that employees may be vulnerable to phishing messages that imitate legitimate IT support and password-management processes.

Campaign A and Campaign C also demonstrated employee susceptibility, highlighting the need for targeted awareness programmes across HR, executive and general employee groups.

The quantitative calculations demonstrate how phishing simulation results can be translated into financial terms to support executive decision-making.

Under the lab's simplified assumptions, Campaign B produces a projected 600 credential submissions, 150 expected breach-equivalent outcomes and $652.5 million in modelled financial exposure.

The control analysis further demonstrates the potential financial benefits of investing in MFA, security awareness training and email filtering.

However, quantitative GRC reporting must distinguish between observed results, mathematical projections and assumptions. The $652.5 million figure is useful for completing the exercise and illustrating the potential financial consequences of the supplied model. It should not be represented as a validated annual loss forecast until the organisation establishes how credential compromise translates into distinct breach incidents and annual occurrence frequency.

GlobalTech should prioritise MFA implementation, targeted security awareness training, email-layer protection and continuous measurement.

The proposed security investment should be implemented in stages, supported by measurable security KPIs and regularly reviewed using actual incident and loss data.

Ultimately, effective GRC practice goes beyond identifying risks. It involves analysing evidence, evaluating potential business impacts, quantifying exposure, recommending appropriate controls and communicating findings in a language that supports informed management decisions.

The ability to quantify risk and demonstrate the value of security investments is an essential skill for a GRC professional.

REFERENCES

Cybersecurity and Infrastructure Security Agency. (2022, October). Implementing phishing-resistant MFA.

https://www.cisa.gov/sites/default/files/2023-01/fact-sheet-implementing-phishing-resistant-mfa-508c.pdf

Cybersecurity and Infrastructure Security Agency, National Security Agency, Federal Bureau of Investigation, & Multi-State Information Sharing and Analysis Center. (2023, October). Phishing guidance: Stopping the attack cycle at phase one.

https://www.cisa.gov/sites/default/files/2025-03/Phishing%20Guidance%20-%20Stopping%20the%20Attack%20Cycle%20at%20Phase%20One%20508.pdf

GlobalTech Inc. (n.d.). Lab 3: Advanced GRC phishing simulation & quantitative risk analysis [Internal training brief]. Supplied lab scenario, campaign dataset, control assumptions and deliverables.

National Institute of Standards and Technology. (2012). Guide for conducting risk assessments (NIST Special Publication 800-30 Rev. 1). U.S. Department of Commerce.

https://doi.org/10.6028/NIST.SP.800-30r1

Study guide: Quantitative risk calculations for GRC professionals. (n.d.). [Internal training material]. Supplied formulas and worked examples for phishing metrics, Annualized Loss Expectancy, confidence intervals, ROI and control effectiveness.

AI Usage Declaration

ChatGPT (OpenAI) and Microsoft Copilot were used for brainstorming, report structuring and editing. AI-assisted outputs were reviewed, I remain responsible for the accuracy and final content of this report.

APPENDIX A – FORMULA REFERENCE

The following formulas were used throughout the assessment.

No.	Metric	Formula
1	Email Open Rate	(Emails Opened / Emails Sent) × 100
2	Click-Through Rate	(Emails Clicked / Emails Sent) × 100

3	Credential-Submission Rate	(Credentials Submitted / Emails Sent) × 100
4	Additional Data-Entry Rate	(Additional Data Entries / Emails Sent) × 100
5	Open-to-Click Conversion	(Emails Clicked / Emails Opened) × 100
6	Post-Click Credential Conversion	(Credentials Submitted / Emails Clicked) × 100
7	Projected Credential Submissions	Total Employees × Credential-Submission Rate
8	Expected Breach-Equivalent Outcomes	Projected Credential Submissions × Conditional Breach Probability
9	Annualized Loss Expectancy	SLE × ARO
10	Risk Reduction	Current ALE × Control Effectiveness
11	New Risk	Current ALE × (1 – Control Effectiveness)
12	Return on Investment	[(Benefit – Cost) / Cost] × 100
13	95% Confidence Interval	$p \pm 1.96 \times \sqrt{[p(1 - p)/n]}$
14	Break-Even Breach-Equivalents	Total Investment / Cost per Breach

Key Financial Terms

Term	Meaning
SLE	Single Loss Expectancy: estimated financial impact of one loss event
ARO	Annual Rate of Occurrence: expected frequency of the loss event per year
ALE	Annualized Loss Expectancy: estimated annual financial exposure
ROI	Return on Investment: financial return relative to investment cost
MFA	Multi-Factor Authentication: authentication requiring additional verification
CTR	Click-Through Rate: percentage of emails sent that resulted in a link click
CI	Confidence Interval: a statistical range used to express uncertainty around an estimate